

Google Cloud focuses on curated open source software

According to Google Cloud VP of Infrastructure Eric Brewer, open source technologies will be used by four out of five developers by 2025. The goal of curated open source is to increase supply chain security while adding a higher standard of accountability. This is necessary “to operate the applications that will power our future,” Brewer stated in a blog post. He mentioned laws from the US government, such as the Federal Risk and Authorization Management Program (FedRAMP) and President Biden’s Cybersecurity Executive Order.

Curated open source depends on an individual or group of curators who examine open source software packages to find flaws and fix them. For instance, curators implement automated testing that streamlines open source security, track new dependencies, and update existing ones.

Today, open source curation is only available on a small scale through packages linked to supported Linux versions or premium open source platforms like Apache Spark. Brewer noted that currently “most of the packages we depend on are not curated.” This will need to alter given the broad risk.



According to Brewer, the carefully selected open source packages offered by Google Cloud “allow enterprises to gain from the same end-to-end security capabilities and practices that we apply to our own OSS portfolio at Google Cloud.”

OSS is popular but needs automation for better cybersecurity

According to estimates, open source software (OSS) now makes up between 80 and 90 per cent of all software. Even though it has been a fantastic accelerator for software development, it produces a big surface area that needs to be controlled because there are millions of packages published anonymously that developers use to build software. Most open source programmers behave honourably; they care about making other programmers’ lives simpler. Because there is no financial reward for publishing an OSS package and a lot of negative feedback in comment threads, it is a thankless profession. “The most frequently encountered bad behaviour is rudeness (45% witnessed, 16% experienced), followed by name calling (20% witnessed, 5% experienced) and stereotyping (11% witnessed, 3% experienced),” according to GitHub’s Open Source Survey.



Sadly, not all OSS packages can be relied upon. Since it is difficult to trace who made changes to open source code, it is nearly impossible to pin down bad actors that intend to jeopardise the integrity of the code. Harmful open source software packages have occasionally been injected to highlight the fact that major corporations use them but do not support their development, as well as just for malicious purposes.

Knowing the size of your application’s surface area is the first step in determining the type of hazard you face. To acquire visibility into the OSS packages and version numbers being used in your software, it is important to include automation into your cybersecurity procedures. You can fit this technique into your developers’ workflow by starting as early as the integrated development environment (IDE), preventing any delays.

Supply-chain levels for software artifacts (SLSA) is the industry standard; it is a set of guidelines and safeguards intended to prevent tampering, enhance integrity, and secure packages and infrastructure in your projects.

Tech Mahindra sets up a Google Cloud delivery centre In Mexico

Tech Mahindra, a supplier of business re-engineering, consulting, and digital transformation services and solutions, has announced the opening of its Google Cloud delivery centre in Guadalajara, Mexico. The centre will focus on Google Cloud-centric solutions that help clients manage workloads, update infrastructure, and use cloud native and open source technologies.